

FACULTAD DE ECONOMÍA, EMPRESA Y NEGOCIOS.
Metodologías de Desarrollo de Software 0

ANÁLISIS DE RIESGOS, CONTROLES DE SEGURIDAD

y Estudio de Factibilidad de SumaControl

Catedrático/a:
Lcda. Ana Lissette Girón de Bermúdez

Presentado por:
Victor Eduardo Alonzo López
Samuel Rafael Martínez Ramírez
Gonzalo Ricardo Guzmán Sosa

Actividad Asíncrona Grupal — Seguridad Informática y Factibilidad
Antiguo Cuscatlán, Noviembre de 2026

CONTROL DEL DOCUMENTO

Documento	Análisis de Riesgos, Controles de Seguridad y Estudio de Factibilidad de SumaControl
Actividad	Actividad Asíncrona Grupal (MDS 0) — entrega en Google Classroom antes del 17 de noviembre de 2026, 23:59 h
Versión	1.0 — Noviembre de 2026
Equipo	Grupo N.º 1, Sección 1-1 — Alonzo López (PO), Martínez Ramírez (SM), Guzmán Sosa (Dev)
Base técnica	Rama develop del repositorio (commit 17699ba), que ya integra los Sprints 6 y 7
Repositorio	https://github.com/202401579-hue/Proyecto-Integrador
Carpeta de evidencia	https://github.com/202401579-hue/Proyecto-Integrador/tree/develop/docs/seguridad-y-factibilidad

1. INTRODUCCIÓN Y ALCANCE

SumaControl ya funciona: registra proveedores y citas, clasifica la puntualidad, administra la cola de descarga y controla quién puede hacer qué. Falta responder dos preguntas que cualquier jurado técnico hará: qué podría salir mal con la seguridad del sistema y si el proyecto es viable como solución real. Este informe responde ambas con datos del sistema construido, y además consolida la Sección 1 (Inicio del Proyecto) del Documento Maestro.

El informe separa siempre lo que existe de lo que se propone. Cada control se clasifica como Vigente (está en el código y se puede verificar), Parcial (existe en puntos concretos) o Propuesto (no está implementado). La evidencia de los controles vigentes son archivos del repositorio y 40 pruebas unitarias ejecutadas para este informe. Las cifras económicas son una estimación con supuestos declarados, que el equipo puede ajustar con mediciones del centro de distribución.

Sección	Contenido	Criterio de la rúbrica
2 y 3	Análisis de riesgos (10 riesgos valorados) y controles de seguridad (16 controles)	Riesgos y controles — 4 pts
4	Factibilidad técnica, económica y operativa	Factibilidad — 4 pts
5	Consolidación de la Sección 1: Project Charter, Ishikawa, BPMN y factibilidad	Sección 1 — 2 pts
6 y 7	Observaciones, limitaciones, cierre y declaración de uso de IA	Transparencia

2. ANÁLISIS DE RIESGOS DE SEGURIDAD

Se identificaron los riesgos recorriendo la superficie real del sistema: 13 grupos de rutas bajo /api, un inicio de sesión público, un frontend en el puerto 3000, una API en el 4000 y MongoDB en el 27017. Cada riesgo se apoya en una vulnerabilidad observable en el código, no en una lista genérica.

2.1 Activos que se protegen

Activo	Dónde vive	Qué se pierde si se compromete
Credenciales y sesiones	usuarios (hash bcrypt), tokens JWT	Suplantación de un operador, coordinador o administrador
Datos operativos	pedidos, proveedores, descargas, gateways	Programación alterada, historial falso, decisiones logísticas erróneas
Bitácora de eventos	eventos (solo inserción)	Pérdida de trazabilidad y de la prueba de quién hizo qué
Configuración y permisos	parametros, roles	Reglas de negocio modificadas o permisos otorgados indebidamente
Secretos	JWT_SECRET, MONGO_URI, secreto TOTP	Falsificación de tokens o acceso directo a la base
Disponibilidad	API (4000) y MongoDB (27017)	La garita no puede registrar llegadas; se pasa a contingencia manual

2.2 Metodología de valoración

Cada riesgo se valora con probabilidad (1 a 5) por impacto (1 a 5). El puntaje, de 1 a 25, define el nivel. Se calcula dos veces: el riesgo actual, con solo los controles vigentes, y el riesgo residual, suponiendo que se implementen los controles propuestos.

Puntaje	Nivel	Tratamiento esperado
15 a 25	Crítico	Resolver antes de pasar a producción
10 a 14	Alto	Plan de mitigación con responsable y fecha
5 a 9	Medio	Mitigar en el siguiente ciclo y monitorear
1 a 4	Bajo	Aceptar y revisar periódicamente

Probabilidad: 1 casi imposible, 3 posible en el uso normal, 5 casi seguro. Impacto: 1 molestia menor, 3 afecta la operación de un turno, 5 compromete datos o accesos de todo el sistema.

2.3 Matriz de riesgos

ID	Amenaza	Vulnerabilidad observada en el sistema	P × I	Nivel
R-01	Fuerza bruta o relleno de credenciales sobre el inicio de sesión	POST /api/auth/login no limita los intentos con contraseña; el límite de 5 solo existe en el segundo factor. La política exige 8 caracteres sin complejidad y el MFA no es obligatorio por defecto (mfaObligatorio: false).	3 × 4 = 12	Alto
R-02	Robo o reutilización del token de sesión	El token de acceso se guarda en localStorage y vale 8 h sin revocación individual; si hubiera un XSS o una sesión abierta en un equipo compartido, el token sería utilizable. React escapa el contenido y el código no usa dangerouslySetInnerHTML.	3 × 4 = 12	Alto

ID	Amenaza	Vulnerabilidad observada en el sistema	P × I	Nivel
R-03	Inyección NoSQL o datos maliciosos en el cuerpo de la petición	No hay sanitización global del body. Los puntos críticos sí validan: el login fuerza String() sobre el correo, /api/eventos valida el tipo de cada filtro y Mongoose castea los campos y aplica validadores; el $jsonSchema es una segunda barrera en la base.	2 × 4 = 8	Medio
R-04	Escalamiento de privilegios por RBAC mal configurado	El permiso es por módulo completo, no por acción: quien tiene "pedidos" puede usar todo el módulo. Se mitiga con la reconsulta en cada petición, el Administrador protegido y la regla de no modificar los propios roles.	2 × 4 = 8	Medio
R-05	Intercepción de credenciales y tokens en tránsito	El repositorio no configura TLS: la API y el frontend responden por HTTP. Contraseñas y JWT viajarían en claro por la red. CORS protege al navegador, no frente a un espía de red.	3 × 5 = 15	Crítico
R-06	Filtración o debilidad de los secretos de configuración	.env está fuera del repositorio y obtenerSecreto() impide autenticar (responde 500) si falta JWT_SECRET, pero el sistema no valida la fortaleza del secreto ni exige autenticación en MongoDB; con un secreto débil se pueden falsificar tokens.	2 × 5 = 10	Alto
R-07	Compromiso de la base de datos con secretos TOTP legibles	El hash de la contraseña y los códigos de recuperación están hasheados con bcrypt, pero twoFactorSecret se guarda sin cifrar (select: false evita que viaje, no que se lea en la base).	2 × 4 = 8	Medio
R-08	Repudio y falta de trazabilidad de los eventos de seguridad	La bitácora es de solo inserción y registra eventos operativos y de roles (13 acciones), pero no los inicios de sesión fallidos o exitosos ni los bloqueos del MFA: un ataque de adivinación no deja rastro.	3 × 3 = 9	Medio
R-09	Denegación de servicio por agotamiento de recursos	No hay límite general de peticiones; express.json() usa su límite por defecto (100 kb) y el tablero consulta cada 5 s por pestaña visible. Un volumen alto de logins consume CPU por bcrypt.	3 × 3 = 9	Medio
R-10	Pérdida o corrupción de datos operativos	Hay baja lógica, validadores y bitácora inmutable, pero el repositorio no incluye respaldos automáticos ni procedimiento de restauración verificado.	2 × 5 = 10	Alto

Los 10 riesgos superan el mínimo de 4 que pide la lista de chequeo y cubren autenticación, autorización, datos, transporte, secretos, trazabilidad, disponibilidad y respaldo.

2.4 Mapa de calor: riesgo actual y residual

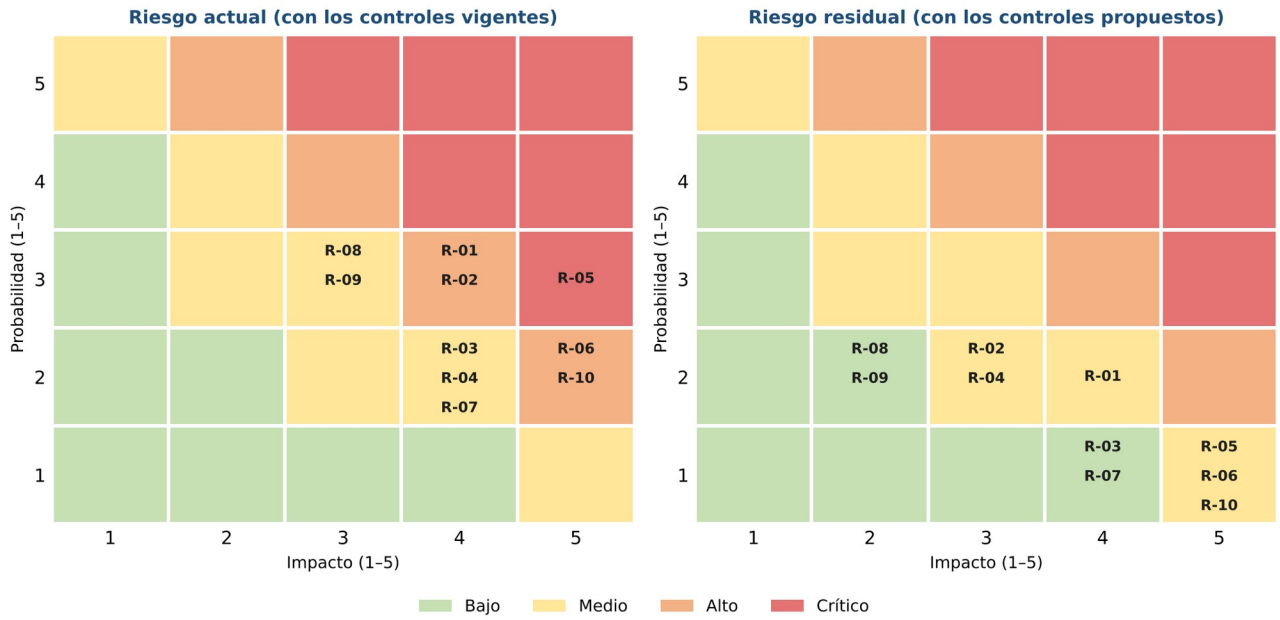


Figura 1. Mapa de calor de los 10 riesgos antes y después de los controles propuestos.

ID	Actual	Controles que lo tratan	Residual
R-01	12 · Alto	C-02, C-03, C-04 (vigentes); C-13 y MFA obligatorio al Administrador (propuestos)	8 · Medio
R-02	12 · Alto	C-01, C-05 (vigentes); C-13 y C-16 (propuestos)	6 · Medio
R-03	8 · Medio	C-07 (parcial); C-14 (propuesto)	4 · Bajo
R-04	8 · Medio	C-05, C-06 (vigentes); permisos por acción (propuesto)	6 · Medio
R-05	15 · Crítico	C-08 (vigente, no cubre este riesgo); C-12 (propuesto)	5 · Medio
R-06	10 · Alto	C-09 (vigente); secreto robusto y MongoDB autenticado (propuestos)	5 · Medio
R-07	8 · Medio	C-02, C-03 (vigentes); cifrado del secreto TOTP (propuesto)	4 · Bajo
R-08	9 · Medio	C-10 (parcial); eventos de autenticación (propuesto)	4 · Bajo
R-09	9 · Medio	C-13 (propuesto); límites del proxy inverso	4 · Bajo
R-10	10 · Alto	C-10, C-11 (vigentes); C-15 (propuesto)	5 · Medio

2.5 Lectura del análisis

El riesgo más alto es el transporte sin cifrar (R-05, crítico). Es el único que hoy alcanza el nivel crítico y el que tiene el control más barato: poner un proxy inverso con certificado. Es la primera prioridad antes de cualquier despliegue fuera de la red local.

Los riesgos altos giran alrededor de la sesión y el acceso. R-01 (fuerza bruta) y R-02 (robo de token) se reducen con límite de intentos, cabeceras seguras y MFA obligatorio para el Administrador. R-06 y R-10 se tratan con secretos robustos y respaldos.

Lo que ya está bien resuelto. La contraseña nunca viaja ni se guarda en claro, el login no revela si un correo existe, los permisos se reconsultan en cada petición y la bitácora no se puede reescribir. Eso explica por qué ningún riesgo de autorización está por encima de nivel medio.

El riesgo residual no es cero. Después de los controles propuestos quedan riesgos de nivel medio (R-01, R-02, R-04, R-05, R-06, R-10), porque el impacto de una brecha en credenciales o datos sigue siendo alto aunque la probabilidad baje.

3. CONTROLES DE SEGURIDAD

3.1 Inventario de controles y estado real

Todos los controles Vigentes se verificaron en el código de la rama develop. La columna de evidencia indica el archivo (carpeta backend/src) y, cuando existe, la prueba que lo ejercita.

ID	Control	Riesgos	Estado	Evidencia
C-01	Autenticación JWT con dos tipos de token (ACCESS 8 h; MFA_TEMP 5 min con jti aleatorio)	R-02	Vigente	services/tokens.ts, middlewares/verificarToken.ts · tokens.test.ts
C-02	Hash de contraseñas con bcrypt (salt, 10 rondas, versión asíncrona, select: false)	R-01, R-07	Vigente	models/Usuario.ts
C-03	Segundo factor TOTP, códigos de recuperación hasheados y límite de 5 intentos por token	R-01, R-07	Vigente	services/mfa.ts, services/intentosMfa.ts · mfa.test.ts (PU-19 a PU-25)
C-04	Respuesta genérica en el login ("Credenciales inválidas"); la baja se verifica después de la clave	R-01	Vigente	controllers/authController.ts
C-05	RBAC dinámico: checkPermission reconsulta usuario y roles activos en cada petición	R-02, R-04	Vigente	middlewares/checkPermission.ts, services/permisos.ts · permisos.test.ts · pruebas/casos-rbac.ts
C-06	Administrador protegido y autoprotección (no modifica sus roles ni se da de baja: 409)	R-04	Vigente	services/roles.ts, controllers/usuarioController.ts · permisos.test.ts
C-07	Validación y coerción de entrada: String(), tipos, ObjectId.isValid, validadores Mongoose y $jsonSchema	R-03	Parcial	authController.ts, eventoController.ts, models/*, docs/arquitectura-y-datos/schema.js
C-08	CORS restringido al origen configurado (FRONTEND_URL)	R-03	Vigente	server.ts
C-09	Secretos por variables de entorno; .env fuera del repositorio; la autenticación falla con 500 si falta JWT_SECRET	R-06	Vigente	.gitignore, .env.example, services/tokens.ts
C-10	Bitácora de solo inserción (los middlewares del modelo bloquean update, replace y delete)	R-08, R-10	Parcial	models/Evento.ts, services/eventos.ts
C-11	Baja lógica: no se borran documentos y las consultas filtran por activo	R-10	Vigente	services/borradoLogico.ts, models/auditoria.ts
C-12	HTTPS/TLS con proxy inverso, certificado y cabecera HSTS	R-05	Propuesto	Sección 3.2.4
C-13	Límite de intentos en el login, límite general de peticiones y cabeceras seguras (helmet)	R-01, R-02, R-09	Propuesto	Sección 3.2.4
C-14	Sanitización global de filtros (sanitizeFilter de Mongoose) y validación de esquema de entrada	R-03	Propuesto	Sección 3.2.3
C-15	Respaldos automáticos con mongodump y prueba mensual de restauración	R-10	Propuesto	Plan de Soporte y Mantenimiento (Semana 15), sección 3.4
C-16	Sesión en el navegador: cookie httpOnly o token en memoria y política CSP	R-02	Propuesto	Sección 3.2.1

Resumen: 9 controles vigentes, 2 parciales y 5 propuestos.

3.2 Los cinco controles que exige la lista de chequeo

3.2.1 JWT: autenticación sin estado, con dos tipos de token

El sistema emite dos tokens distintos. El token de acceso (ACCESS) dura 8 horas y lleva id, correo, roles y permisos; es el que abre las rutas operativas. El token temporal (MFA_TEMP) dura 5 minutos, lleva un jti aleatorio generado con randomUUID y solo sirve para completar el segundo factor. verificarToken rechaza un token temporal en las rutas operativas y rechaza cualquier token que no traiga el claim de permisos, de modo que las sesiones anteriores al Sprint 7 reciben 401.

Aspecto	Implementación
Firma y vencimiento	jwt.sign / jwt.verify con JWT_SECRET; si falta el secreto, la autenticación responde 500 en lugar de usar uno improvisado
Contenido del payload	Solo identidad no sensible: nunca contraseña ni hash (el payload es legible)
Qué NO decide el token	La autorización: checkPermission reconsulta la base en cada petición
Almacenamiento en el cliente	localStorage (acceso) y sessionStorage (temporal MFA); límite conocido ante XSS
Mejora propuesta (C-16)	Cookie httpOnly con SameSite o token en memoria, más una política CSP

3.2.2 RBAC dinámico y bcrypt

La autorización usa roles dinámicos: el Administrador crea roles con permisos de una lista cerrada de ocho módulos (usuarios, roles, proveedores, pedidos, gateways, descargas, cola y kpis). checkPermission carga al usuario y sus roles activos y une los permisos en cada petición, por lo que quitar un permiso o dar de baja a un usuario se aplica de inmediato. El rol Administrador no puede desactivarse, renombrarse ni quedar sin los permisos usuarios y roles, y un administrador no puede modificar sus propios roles ni darse de baja.

Las contraseñas se guardan con bcrypt: salt generado por llamada, 10 rondas, versión asíncrona para no bloquear el hilo de Node y campo con select: false para que el hash no viaje en consultas normales. Los códigos de recuperación del MFA también se hashean con bcrypt y se comparan recorriendo todos los hashes, para no filtrar por tiempo cuál coincidió. Límite conocido: el permiso es por módulo completo y no por acción, de modo que un Operador con "pedidos" puede usar todo ese módulo.

3.2.3 Sanitización y validación de entrada

Hoy la defensa es por puntos críticos y por capas, no una sanitización global. En el login, el correo se fuerza a texto con String(correo) antes de consultar, de modo que un objeto como {"$ne": null} no puede convertirse en un operador. En /api/eventos se comprueba que cada filtro sea texto y una fecha válida. Mongoose castea los tipos y aplica los validadores del esquema, y los validadores $jsonSchema de la base (carpeta docs/arquitectura-y-datos) rechazan documentos mal formados incluso si el código fallara. La brecha es que no hay una barrera uniforme para todo el body.

Propuesta C-14 (no implementada): activar la opción sanitizeFilter de Mongoose, que trata cualquier operador ($ne, $gt, $where) recibido en un filtro como valor literal, y validar el esquema de cada cuerpo de petición antes del controlador.

```
// backend/src/config/database.ts (propuesta C-14)
mongoose.set('sanitizeFilter', true);

// Para los pocos filtros que sí necesitan operadores, se declaran explícitamente
Pedido.find({ fecha: mongoose.trusted({ $gte: desde }) });
```

3.2.4 HTTPS, límite de intentos y cabeceras seguras

El repositorio no configura TLS ni cabeceras de seguridad. CORS restringe qué sitio puede llamar a la API desde un navegador, pero no protege el tráfico. La propuesta es terminar TLS en un proxy inverso delante de la API y del frontend y añadir dos paquetes pequeños al backend.

```
// backend/src/server.ts (propuesta C-13)
import helmet from 'helmet';
import { rateLimit } from 'express-rate-limit';

app.use(helmet());
app.use(rateLimit({ windowMs: 15 * 60 * 1000, limit: 300, standardHeaders: true }));
app.use('/api/auth/login', rateLimit({ windowMs: 15 * 60 * 1000, limit: 10 }));
```

```
# Proxy inverso (propuesta C-12): Nginx con certificado de Let's Encrypt
server {
  listen 443 ssl;
  server_name sumacontrol.ejemplo.sv;
  ssl_certificate     /etc/letsencrypt/live/sumacontrol/fullchain.pem;
  ssl_certificate_key /etc/letsencrypt/live/sumacontrol/privkey.pem;
  add_header Strict-Transport-Security "max-age=31536000" always;
  location /api/ { proxy_pass http://127.0.0.1:4000; }
  location /     { proxy_pass http://127.0.0.1:3000; }
}
```

Con el límite de intentos del login hay que recordar que el contador del MFA vive en memoria del proceso: si el servidor se reinicia, los conteos se pierden. La decisión es deliberada y está justificada en el código (el token temporal dura solo 5 minutos), pero conviene conocerla.

3.3 Hoja de ruta de endurecimiento

Prioridad	Controles	Riesgos	Responsable	Esfuerzo
1 — Antes de producción	C-12 HTTPS · C-13 límite de intentos y helmet · MFA obligatorio para el Administrador	R-05, R-01, R-09	PON 0 (backend) · GRE 1 / GSO 0 (proxy y certificado)	≈ 11 h
2 — Primer ciclo posterior	C-14 sanitización global · eventos de autenticación en la bitácora · secreto JWT robusto y MongoDB autenticado	R-03, R-08, R-06	PON 0 · GSO 0	≈ 14 h
3 — Evolución	C-15 respaldos automáticos · C-16 sesión en cookie httpOnly y CSP · cifrado del secreto TOTP	R-10, R-02, R-07	GSO 0 · PON 0	≈ 24 h

El esfuerzo total estimado es de 49 h. Su costo entra en la factibilidad económica de la Sección 4.2.

3.4 Evidencia de verificación

Para este informe se ejecutaron las pruebas unitarias de seguridad del backend sobre la rama develop (commit 17699ba) con Jest. Resultado: 4 suites y 40 pruebas, todas aprobadas.

Suite	Control	Qué verifica
tokens.test.ts	C-01	ACCESS con roles y permisos; rechazo del token heredado sin permisos (401); MFA_TEMP separado y de 5 minutos
login.test.ts (PU-19, PU-20)	C-03	Los cuatro casos del paso siguiente del login; nunca hay acceso directo si el MFA es obligatorio o ya está configurado
mfa.test.ts (PU-21 a PU-25)	C-03	Formato del código TOTP, códigos de recuperación únicos y hasheados, límite de 5 intentos contado por token

Suite	Control	Qué verifica
permisos.test.ts	C-05, C-06	Unión de permisos sin duplicados, lista cerrada, Administrador protegido (no se renombra, desactiva ni pierde permisos)

Los casos funcionales de RBAC (backend/src/pruebas/casos-rbac.ts) existen en el repositorio y requieren un entorno con base de datos; no se ejecutaron para este informe y se consignan en la Sección 6.

4. ESTUDIO DE FACTIBILIDAD

La factibilidad se evalúa sobre el sistema que ya se construyó, no sobre una idea. En cada dimensión se indica el dato que la sustenta y la condición que debe cumplirse.

4.1 Factibilidad técnica

Criterio	Dato del proyecto	Valoración
Tecnología	Next.js 16 y React 19 (frontend), Express 5 con TypeScript (API), MongoDB 8 con Mongoose 9. Todas son tecnologías maduras, de código abierto y con comunidad activa	Favorable
Capacidad del equipo	Tres integrantes con roles de PO, SM y Dev, y cinco asignaturas que cubren frontend, backend, algoritmos (EDA 0), servidores (GSO 0) y redes (GRE 1)	Favorable
Evidencia de construcción	13 grupos de rutas, 13 controladores, 8 colecciones, 14 archivos de pruebas unitarias y 7 sprints entregados, con seguridad JWT, MFA y RBAC dinámico	Favorable
Motor de cola	Implementado en TypeScript dentro del backend (heap binario con aging), sin microservicio aparte; la prioridad es configurable por parámetros	Favorable
Rendimiento y escala	Cinco gateways y una jornada de 7:00 a 17:00 de lunes a sábado generan un volumen bajo para una API Express y una base MongoDB; el sondeo del tablero es cada 5 s	Favorable
Integración	El frontend consume la API por HTTP/REST con JSON; no depende de servicios externos de terceros	Favorable
Seguridad	Faltan HTTPS, límite de intentos y respaldos automáticos (Secciones 2 y 3)	Condicionada

Dictamen técnico: factible. El sistema ya existe y usa tecnología estándar. La condición es cerrar las brechas de la Prioridad 1 de la hoja de ruta antes de operar fuera de la red local.

4.2 Factibilidad económica

El proyecto es académico y no tuvo desembolso en efectivo; aun así, su viabilidad se evalúa como si el centro de distribución lo adoptara. Todos los valores son supuestos declarados del equipo y están en la tabla siguiente para que se puedan corregir sin reescribir el análisis.

Supuestos declarados

ID	Supuesto	Valor	Origen
S-01	Trabajo de desarrollo: 3 integrantes × 12 semanas × 8 h por semana	288 h	Estimación del equipo
S-02	Tarifa referencial de un perfil junior	$6.00/h	Supuesto; ajustar al mercado
S-03	Esfuerzo de los controles de seguridad propuestos	49 h	Sección 3.3
S-04	Servidor en la nube: 2 vCPU y 4 GB de RAM, $24 al mes; respaldos del proveedor ≈ 20 % del servidor; dominio $15 al año	$360.60/año	Precios de lista del proveedor en 2026; verificar al contratar
S-05	Alternativa local (servidor del centro, GSO 0): energía y mantenimiento marginal	$120/año	Supuesto
S-06	Mantenimiento: 4 h al mes	$288/año	Plan de mantenimiento (Semana 15)
S-07	Costo hora de personal operativo cargado	$4.00/h	Supuesto; reemplazar por dato real del centro

ID	Supuesto	Valor	Origen
S-08	Días de operación al año (lunes a sábado, parámetro DIAS_HABILES)	312 días	Parámetros del sistema
S-09	Horizonte y tasa de descuento	3 años, 10 %	Supuesto

Costos

Concepto	Valor	Observación
Desarrollo (valor referencial del trabajo)	$1,728	288 h × $6.00; no es un desembolso
Controles de seguridad propuestos	$294	49 h × $6.00; el certificado de Let's Encrypt no tiene costo
Herramientas	$0	Node.js, Next.js, Express, MongoDB Community, Git y GitHub son de uso gratuito; Jira para el backlog (se asume el plan gratuito)
Inversión inicial total	$2,022	Desarrollo más seguridad
Operación anual en la nube	$360.60	Servidor, respaldos y dominio
Mantenimiento anual	$288	4 h al mes
Costo anual recurrente	$648.60	Operación más mantenimiento

MongoDB Atlas queda descartado como alternativa de base de datos: el nivel gratuito M0 ofrece 512 MB, sin respaldos ni acuerdo de nivel de servicio, y el primer nivel dedicado (M10) cuesta unos $57 al mes, desproporcionado para el volumen de este centro. La base corre en el mismo servidor que la API.

Beneficios y resultados por escenario

El beneficio que se cuantifica es el tiempo de personal ahorrado por arribo: registrar la llegada, clasificar la puntualidad y asignar el gateway dejan de hacerse con llamadas y hojas de cálculo. La fórmula es arribos al día × minutos ahorrados por arribo ÷ 60 × costo hora × días al año. Los beneficios no cuantificados (menor espera de los camiones, indicadores para decidir, trazabilidad) quedan fuera del cálculo, de modo que la estimación es prudente.

Escenario	Supuesto diario	Beneficio anual	Neto anual	VAN a 3 años	B/C	Recuperación
Conservador	20 arribos × 4 min	$1,664	$1,015	$503	1.14	24 meses
Esperado	40 arribos × 5 min	$4,160	$3,511	$6,710	2.85	7 meses
Optimista	60 arribos × 8 min	$9,984	$9,335	$21,194	6.83	3 meses

Punto de equilibrio: para recuperar la inversión de $2,022 en 3 años y cubrir los costos recurrentes, el sistema debe ahorrar al menos 64 minutos de personal por día (por ejemplo, 16 arribos con 4 minutos ahorrados cada uno). Por debajo de eso, el proyecto no se paga solo con ahorro de tiempo, y la decisión dependería de los beneficios no cuantificados.

Dictamen económico: factible. Con el escenario conservador, que ya supera el equilibrio, el VAN a 3 años es positivo, y los costos son bajos porque todo el software es de código abierto. La condición es medir el volumen real de arribos y los minutos ahorrados en la fase de pruebas de aceptación para confirmar el supuesto.

4.3 Factibilidad operativa

Criterio	Dato del proyecto	Valoración
Usuarios y roles	Administrador, Coordinador y Operador como roles base, ampliables con roles dinámicos; los perfiles coinciden con los stakeholders directos identificados en la Semana 7	Favorable
Encaje con el proceso	El flujo informatizado (cita, llegada, puntualidad, cola, gateway, descarga) reproduce el proceso real y la jornada configurada, de 7:00 a 17:00 de lunes a sábado	Favorable
Capacitación	Existe el Plan de Capacitación con matriz por perfil, guía del operador y manual del administrador, y los manuales por rol previstos en el Sprint 7	Favorable
Soporte	Plan de soporte en tres niveles (L1, L2, L3) con SLA por severidad y rollback con objetivo de recuperación menor a 15 minutos	Favorable
Despliegue	Plan de Implementación con salida en vivo por fases, pruebas de aceptación con usuarios (UAT) y contingencia manual en garita	Favorable
Resistencia al cambio	Pasar de hojas de cálculo y llamadas a un sistema único exige cambio de hábitos; se mitiga con capacitación por perfil, fase piloto y soporte L1 en garita	Condicionada
Dependencias de operación	La garita necesita conectividad estable; un corte pasa la operación a registro manual hasta restablecer el servicio	Condicionada

Dictamen operativo: factible con condiciones. Las condiciones son una fase piloto con usuarios reales, conectividad estable en la garita y la capacitación previa al uso por perfil.

4.4 Dictamen consolidado

Dimensión	Dictamen	Condición principal
Técnica	Factible	Implementar HTTPS, límite de intentos y respaldos antes de operar fuera de la red local
Económica	Factible	Confirmar al menos 64 min diarios de ahorro con datos reales del centro
Operativa	Factible con condiciones	Fase piloto, conectividad en garita y capacitación previa por perfil

5. CONSOLIDACIÓN DE LA SECCIÓN 1: INICIO DEL PROYECTO

La Sección 1 del Documento Maestro reúne los módulos con los que el proyecto arranca: por qué existe, qué se quiere lograr, quiénes participan, cuál es la causa del problema, cómo es el proceso y si es viable. Esta sección los ordena en un solo expediente y los enlaza con el resto del Documento Maestro.

5.1 Índice de la Sección 1 y trazabilidad

Módulo	Contenido	Fuente	Ubicación
1.1	Project Charter	Guía integradora, Adenda y Acta del equipo	Sección 5.2
1.2	Matriz de stakeholders	Avance de la Semana 7	Sección 5.3
1.3	Problema (5Ws) y causa raíz (5 Porqués)	Avance de la Semana 7	Sección 5.4
1.4	Diagrama de Ishikawa	Elaborado a partir de 1.3	Sección 5.5
1.5	Proceso en BPMN (propuesto)	Elaborado a partir de los diagramas DS-01 y DS-02	Sección 5.7
1.6	Estudio de factibilidad	Este informe	Sección 4

5.2 Project Charter

Proyecto	Sistema de Gestión Logística de Recepción de Proveedores y Desembarque (SumaControl)
Justificación	El centro de distribución no cuenta con un sistema formal: las citas se coordinan por llamadas, correos y hojas de cálculo, la puntualidad se registra a mano y los gateways se asignan sin criterio automatizado. Esto produce desorden y cuellos de botella, sobre todo en horas pico.
Objetivo general	Controlar el proceso de recepción de proveedores, desde la cita hasta el fin de la descarga, en un sistema web integrado.
Objetivos específicos	1) Programar y reprogramar citas. 2) Registrar la llegada real y clasificar la puntualidad (A tiempo, Anticipado, Tardío, Ausente). 3) Administrar una cola de prioridad con aging y asignar gateways compatibles. 4) Controlar el inicio y fin de la descarga y registrar los eventos. 5) Generar indicadores: espera y descarga promedio, puntualidad, ausentismo y utilización de gateways.
Alcance incluido	Los cinco módulos del MVP (proveedores y citas, llegadas y puntualidad, cola y asignación, descarga, historial e indicadores), la autenticación con JWT, el MFA y el control de acceso por roles.
Fuera de alcance	El control de entrada y salida de empleados, rol identificado y descartado por el equipo, y las integraciones con otros sistemas empresariales, que la guía integradora no contempla.
Restricciones	Cinco gateways: del 1 al 4 para carga general y el 5 exclusivo para productos de construcción (RN-08). Jornada de 7:00 a 17:00 de lunes a sábado. Metodología Scrum, estándar IEEE 830/29148 y trazabilidad obligatoria en GitHub.
Hitos académicos	Semana 7: documento de diseño e ingeniería de requisitos (30 %). Semana 13: versión beta funcional y auditoría del repositorio (30 %). Semana 20: sistema desplegado, defensa técnica y manuales (30 %).
Entregas por sprint	Sprints 1 a 5 de la guía integradora (usuarios y citas, llegadas y puntualidad, cola y gateways, descarga y bitácora, pruebas e indicadores), más el Sprint 6 (cola con prioridad y aging) y el Sprint 7 (roles dinámicos y manuales).
Criterios de éxito	Todas las llegadas clasificadas automáticamente, ningún pedido de construcción asignado a un gateway de carga general, y los cuatro indicadores del módulo 5 disponibles en el panel.

Equipo Scrum	Victor Eduardo Alonzo López (Product Owner), Samuel Rafael Martínez Ramírez (Scrum Master), Gonzalo Ricardo Guzmán Sosa (Development Team).
Autoridad	El Product Owner decide el alcance y la prioridad del backlog; el Scrum Master garantiza el proceso; el equipo decide cómo construir cada incremento.

5.3 Matriz de stakeholders

Actor	Tipo	Necesidad clave	Impacto	Técnica
Coordinador Logístico	Directo	Agenda organizada de citas para evitar retrasos y centralizar el control de ingresos	Alto	Entrevista estructurada
Operador de Recepción	Directo	Registrar la hora real de llegada, ver la puntualidad y los gateways disponibles	Alto	Observación directa
Supervisor de Desembarque	Directo	Controlar el inicio y fin de la descarga y liberar los gateways	Medio	Entrevista estructurada
Gerente de Operaciones	Indirecto	Consultar indicadores para evaluar el desempeño y decidir	Alto	Entrevista estructurada
Proveedor (empresa externa)	Externo	Conocer su cita y el gateway asignado para entregar a tiempo	Medio	Encuesta

5.4 Problema y causa raíz

El problema, según la técnica de las 5Ws: en el centro de distribución no existe un sistema formal para gestionar la recepción de proveedores; afecta al Coordinador, al Operador, al Supervisor y al Gerente, e indirectamente a los proveedores; se manifiesta a diario, sobre todo en horas pico y cuando llegan a la vez cargas generales y de construcción. La causa raíz es la ausencia de un sistema integrado con programación de citas, clasificación automática de puntualidad y un motor de colas de prioridad con aging.

Nivel	Pregunta	Respuesta
Porqué 1	¿Por qué hay cuellos de botella y desorden?	No existe una asignación automática y ordenada de gateways cuando llegan varios proveedores a la vez
Porqué 2	¿Por qué no existe esa asignación?	La hace el operador manualmente, sin considerar el tipo de carga ni la prioridad
Porqué 3	¿Por qué es manual y sin reglas?	No hay una herramienta que integre agenda, puntualidad y disponibilidad de gateways
Porqué 4	¿Por qué no hay herramienta integrada?	El control se llevó con hojas de cálculo y registros aislados que no permiten aplicar algoritmos de priorización
Porqué 5	¿Por qué se mantuvo ese control?	No se invirtió en un sistema especializado de recepción y desembarque

5.5 Diagrama de Ishikawa

El Ishikawa organiza en seis categorías las causas del problema. Las causas de los cinco Porqués se distribuyen así: la asignación manual y los canales informales en Procesos y Personas; las hojas de cálculo y la falta de integración en Tecnología; la ausencia de datos e indicadores en Información; y la falta de inversión en Gestión.

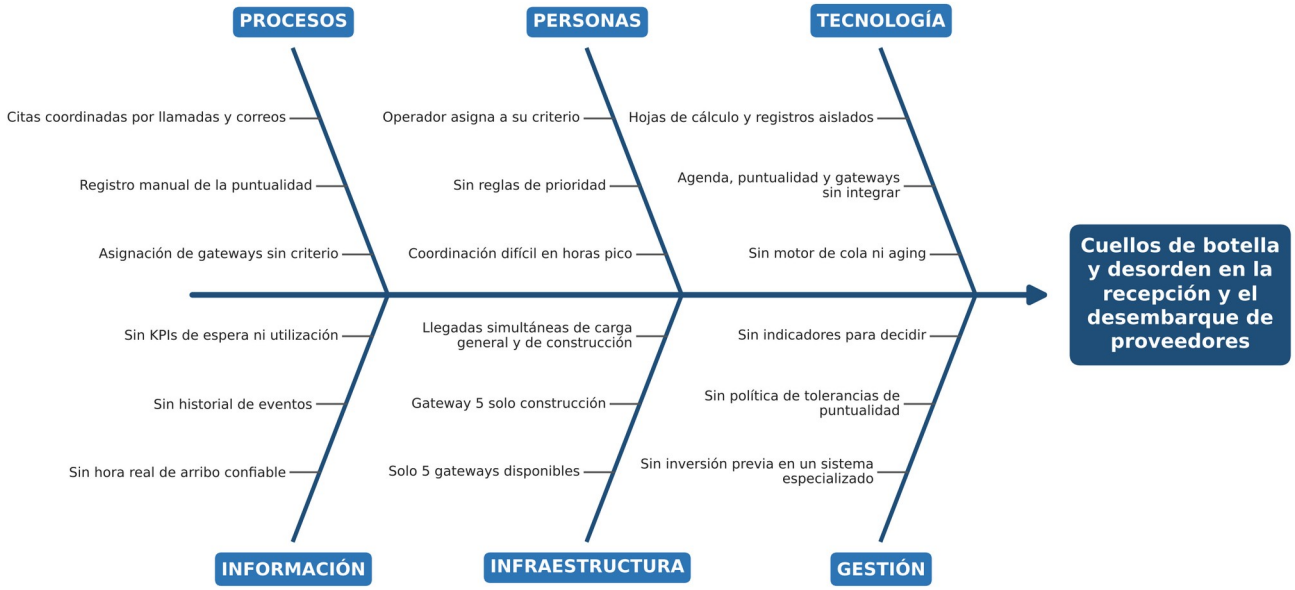


Figura 2. Diagrama de Ishikawa del problema de recepción y desembarque.

5.6 Trazabilidad con el resto del Documento Maestro

Elemento de la Sección 1	Se materializa en	Dónde verificarlo
Objetivo 1: citas	HU-001, caso de uso CU-01	Avances de las Semanas 7 y 9; módulo de pedidos
Objetivo 2: puntualidad	HU-002, CU-02, secuencia DS-01	Avance de la Semana 10; services/puntualidad
Objetivo 3: cola y gateways	HU-003, CU-03, secuencia DS-02, RN-08	Avance de la Semana 10; backend/src/cola
Objetivo 4: descarga y eventos	HU de descarga y bitácora	services/descargas, colección eventos
Objetivo 5: indicadores	Módulo de KPIs	services/kpis, ruta /api/kpis
Seguridad (restricción de acceso)	HU-004 JWT, HU-005 RBAC, HU-006 usuarios	Secciones 2 y 3 de este informe
Arquitectura y datos	Capas, componentes, despliegue y modelo de datos	docs/arquitectura-y-datos
Soporte y mantenimiento	Niveles L1, L2, L3 y planes de mantenimiento	Plan de Soporte y Mantenimiento (Semana 15)

5.7 Proceso en BPMN (modelo propuesto con SumaControl)

El diagrama muestra cómo fluye el proceso con el sistema en operación, con carriles para cada actor. Es la vista de negocio del mismo flujo que los diagramas de secuencia DS-01 (registrar llegada) y DS-02 (asignar gateway) detallan a nivel técnico.

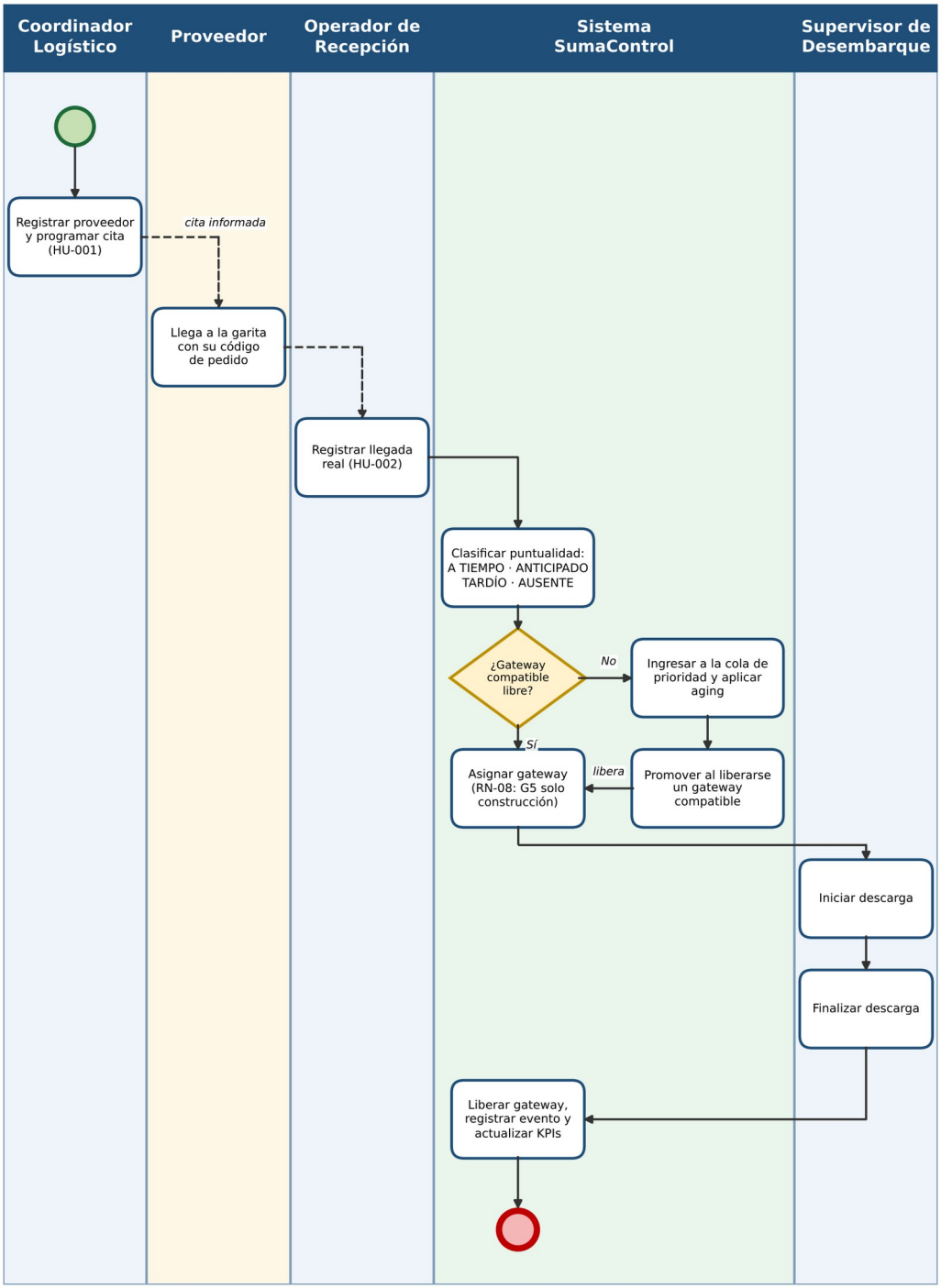


Figura 3. Proceso de recepción y desembarque en BPMN con carriles por actor.

6. OBSERVACIONES Y LIMITACIONES

Al preparar el informe aparecieron diferencias y pendientes. Se consignan para que quien lo lea sepa exactamente qué está hecho y qué no.

OBS-01 — Cinco controles de seguridad no están implementados. HTTPS, límite de intentos y cabeceras seguras, sanitización global, respaldos automáticos y sesión en cookie httpOnly son propuestas (C-12 a C-16). El informe las declara como tales y no como capacidades vigentes.

OBS-02 — Las pruebas funcionales de RBAC no se ejecutaron para este informe. Se ejecutaron las 40 pruebas unitarias de seguridad. Los casos funcionales requieren un entorno con base de datos y quedan pendientes de repetir en la fase de pruebas de aceptación.

OBS-03 — Los números económicos son estimaciones con supuestos. La tarifa, el costo hora del personal, el volumen de arribos y los minutos ahorrados son supuestos declarados (S-01 a S-09). Deben reemplazarse con mediciones del centro antes de usarse en una decisión de inversión.

OBS-04 — Charter, Ishikawa y BPMN se formalizaron en esta entrega. Se elaboraron a partir de los artefactos ya aprobados: la Guía Integradora y su Adenda, el Acta del equipo, los Avances de las Semanas 7 a 10 y los diagramas DS-01 y DS-02. Si el equipo conserva versiones anteriores, deben compararse con las de este documento.

OBS-05 — El motor de cola se implementó en TypeScript. El backlog inicial mencionaba un microservicio en C++ para la cola. La implementación final vive en backend/src/cola y se ejecuta dentro del backend; el informe describe esa versión.

OBS-06 — El contador de intentos del MFA vive en memoria. Es una decisión documentada en el código: el conteo es por token temporal de 5 minutos. Si el servidor se reinicia, los conteos se pierden; con varias instancias del servidor habría que moverlo a una base compartida.

7. CIERRE Y DECLARACIÓN

SumaControl tiene hoy una base de seguridad sólida en autenticación, autorización y manejo de secretos, con brechas identificadas y priorizadas en transporte, límite de intentos y respaldos. El proyecto es viable en lo técnico, lo económico y lo operativo, con tres condiciones concretas, y su Sección 1 queda consolidada en un expediente único y trazable. Lo que no existe todavía se declara como pendiente en lugar de darse por hecho.

7.1 Declaración de uso de Inteligencia Artificial (estándar FEEN)

📌 **DECLARACIÓN OBLIGATORIA:** para la elaboración de este informe el equipo utilizó las herramientas de Inteligencia Artificial Claude y ChatGPT con tres propósitos acotados: (1) recorrer el código del repositorio y ejecutar sus pruebas para verificar que cada afirmación sobre seguridad corresponde al comportamiento real del sistema; (2) apoyar la redacción y la ortografía; y (3) organizar en tablas y diagramas la información producida por el equipo. La valoración de los riesgos, la elección de los controles, los supuestos económicos y los dictámenes de factibilidad fueron definidos y validados por los integrantes del Equipo Scrum. El equipo asume la responsabilidad técnica completa de lo aquí documentado, de conformidad con los Lineamientos del Uso de la Inteligencia Artificial de la FEEN / UJMD.